

คู่มือประกอบการพัฒนาระบบ

Administrative Manual

การพัฒนา API สำหรับผู้ให้บริการ (Relying Party : RP)

รุ่นเอกสาร 1.2.0

17 มีนาคม 2569

สำนักบริหารการทะเบียน กรมการปกครอง

เอกสารควบคุมของสำนักบริหารการทะเบียน กรมการปกครอง
ห้ามทำสำเนาหรือพิมพ์เผยแพร่ส่วนหนึ่งส่วนใดหรือทั้งหมดของเอกสารนี้ก่อนได้รับอนุญาต

ประวัติการแก้ไขเอกสาร

วันที่	รุ่นเอกสาร	รายละเอียดการปรับแก้	หมายเหตุ
17 กันยายน 2563	0.0.01	- จัดทำเอกสารต้นแบบ	
17 กันยายน 2563	0.0.02	- แก้ไข url ของการ Request ทุกข้อ	
28 ตุลาคม 2563	0.0.03	- แก้ไขเรื่อง สถาปัตยกรรมการให้บริการข้อมูลผ่าน BORA API, State [Option] นำออก	
18 ธันวาคม 2563	0.0.04	- แก้ไขชื่อ พารามิเตอร์ oauth2 - เพิ่ม API Introspect - นำ Refresh Token ออก	
9 กุมภาพันธ์ 2564	0.0.05	- เพิ่ม OpenID Connect - แก้ไข API Introspect	
1 มิถุนายน 2564	0.0.06	- แก้ไข API Revoke - ยกเลิก API Consent	
9 กันยายน 2564	0.0.07	- แก้ไข Authentication Request URL	
13 มกราคม 2566	0.8.0	- เปลี่ยน Endpoint ของ service oauth2 - เปลี่ยนชื่อ scope ให้ตรงตามมาตรฐาน - เปลี่ยนรูปแบบข้อมูลของ scope บางตัว ให้ตรงตามมาตรฐาน ได้แก่ address, birthdate, gender - เพิ่ม API สำหรับการทำ Consent	
13 มีนาคม 2566	0.9.0	- เปลี่ยนชื่อเป็นแอปพลิเคชัน ThalD	
13 กรกฎาคม 2566	1.0.0	- เพิ่ม scope	
25 กันยายน 2566	1.0.1	- เปลี่ยนชื่อเว็บไซต์จาก idp เป็น digitalid	
7 สิงหาคม 2567	1.1.0	- เพิ่ม scope	
16 กันยายน 2567	1.1.1	- เพิ่ม scope	
20 ธันวาคม 2568	1.2.0	- ปรับแก้ไขเนื้อหาบทนำ - เพิ่ม verify type	

สารบัญ

หัวข้อ

1. บทนำ
2. ข้อกำหนดในการใช้บริการของระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID)
3. ขั้นตอนการขอใช้บริการ
4. เนื้อหาและขอบเขตการให้บริการ
5. สถาปัตยกรรมระบบ
6. พารามิเตอร์ในกระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตน
 - 6.1. Authentication
 - 6.2. การขอ Token
 - 6.3. การขอ Token Introspect
 - 6.4. การขอ Token Revocation
7. ข้อเสนอแนะ

1. บทนำ

1.1 หลักการและเหตุผล

ประเทศไทยมีการปฏิรูปการบริการให้ปรับไปสู่การบริการผ่านระบบดิจิทัล สอดคล้องกับนโยบายและแผนระดับชาติว่าด้วยการพัฒนาดิจิทัลเพื่อเศรษฐกิจและสังคม 20 ปี (2561 - 2580) ให้เป็นประเทศที่สามารถใช้ประโยชน์จากเทคโนโลยีดิจิทัลอย่างเต็มศักยภาพในการขับเคลื่อนการพัฒนาเศรษฐกิจและสังคมของประเทศไปสู่ความมั่นคง มั่งคั่ง และยั่งยืน โดยหนึ่งในโครงสร้างพื้นฐานทางสารสนเทศที่สำคัญคือการพิสูจน์และยืนยันตัวตนทางดิจิทัลที่สามารถรองรับระบบนิเวศทางดิจิทัล (Digital Ecosystem) ของประเทศไทย เพื่อให้หน่วยงานต่าง ๆ ทั้งภาครัฐและเอกชนนำไปใช้ยืนยันตัวตนผู้ใช้งานเพื่อยกระดับการบริการให้เกิดการบูรณาการการใช้ประโยชน์ร่วมกันอย่างสูงสุด ภายใต้การกำกับดูแลและส่งเสริมให้มีความปลอดภัยทางไซเบอร์ตามมาตรฐานและกฎเกณฑ์ที่เหมาะสมในระดับสากล

คณะรัฐมนตรีได้มีมติเมื่อวันที่ 27 กรกฎาคม 2564 เกี่ยวกับเรื่อง แนวทางการพัฒนาระบบรองรับการพิสูจน์และยืนยันตัวตนทางดิจิทัล หรือ Digital ID ด้วยการพัฒนาแบบพิสูจน์และยืนยันตัวตนด้วยใบหน้าทางดิจิทัล (Face Verification Service - FVS) โดยอนุมัติให้กระทรวงมหาดไทย โดยกรมการปกครองดำเนินการพัฒนาและ จัดให้มีระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA Digital ID) และดำเนินการให้บริการกับหน่วยงานของรัฐและเอกชน และให้กระทรวงดิจิทัลเพื่อเศรษฐกิจและสังคม โดยสำนักงานพัฒนาธุรกรรมทางอิเล็กทรอนิกส์ เป็นที่ปรึกษา ให้คำแนะนำในส่วนงานที่เกี่ยวข้อง เพื่อให้ระบบพิสูจน์และยืนยันตัวตนด้วยใบหน้าทางดิจิทัล (DOPA Digital ID) ที่กรมการปกครองพัฒนา ให้มีความมั่นคงปลอดภัย มีความน่าเชื่อถือ สอดคล้องตามกฎหมาย หลักเกณฑ์ และมาตรฐานที่เกี่ยวข้อง

กรมการปกครองได้พัฒนาระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) สามารถรองรับให้บริการเต็มรูปแบบกับประชาชนผู้มีบัตรประจำตัวประชาชนทั้งหมด ในวันที่ 20 มีนาคม 2566 โดยมีแอปพลิเคชัน ThaiID เป็นโปรแกรมสำหรับเปลี่ยนอุปกรณ์โทรศัพท์เคลื่อนที่ของประชาชนให้เป็นอุปกรณ์ยืนยันตัวตน (Authenticator) เพื่อใช้งานร่วมกับระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) ซึ่งปัจจุบันมีประชาชนผู้ที่มีบัตรฯ ลงทะเบียนในแอปพลิเคชัน ThaiID จำนวนทั้งหมด 30,677,695 คน (ข้อมูล ณ วันที่ 17 มีนาคม 2569) และ ได้จัดทำคู่มือประกอบการพัฒนาระบบ (Administrative Manual) การพัฒนาเชื่อมโยง API สำหรับผู้ให้บริการ (Relying Party : RP) สำหรับสนับสนุนการพัฒนาระบบของหน่วยงานที่ได้รับอนุญาตเชื่อมโยงระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) ของกรมการปกครอง เพื่อให้การปฏิบัติหน้าที่และการบริการประชาชนให้สะดวก รวดเร็ว มีประสิทธิภาพ และมีความมั่นคงปลอดภัยมากยิ่งขึ้น

1.2 วัตถุประสงค์

เพื่อให้หน่วยงานผู้ให้บริการเข้าใจการทำงานและวิธีการเชื่อมโยงของระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) ของกรมการปกครอง ได้อย่างถูกต้อง ปลอดภัย และมีประสิทธิภาพ

2. ข้อกำหนดในการใช้บริการของระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID)

เพื่อให้การบริการข้อมูลและการเชื่อมต่อบริการเป็นไปอย่างมีประสิทธิภาพและได้มาตรฐานการรักษาความมั่นคง ปลอดภัย ระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) ของกรมการปกครอง จึงได้รับการออกแบบ สถาปัตยกรรมการทำงาน โดยแบ่งองค์ประกอบหลักออกเป็น 3 ส่วนสำคัญที่ทำงานร่วมกัน ดังนี้

2.1 ผู้ให้บริการพิสูจน์และยืนยันตัวตน (Identity Provider: IdP)

ทำหน้าที่เป็นระบบศูนย์กลางในการพิสูจน์และยืนยันตัวตนทางดิจิทัล ภายใต้การกำกับดูแลของ กรมการปกครอง มีหน้าที่ตรวจสอบความถูกต้องของบุคคลและบริหารจัดการกระบวนการยืนยันตัวตนผ่านระบบ API โดยมีข้อกำหนด ดังนี้

- รองรับระดับความน่าเชื่อถือของการพิสูจน์ตัวตน (Identity Assurance Level: IAL) ที่ระดับ 2.3
- รองรับระดับความน่าเชื่อถือของการยืนยันตัวตน (Authentication Assurance Level: AAL) ที่ระดับ 2
- สิทธิ์ในการตรวจสอบ: กรมการปกครองขอสงวนสิทธิ์ในการตรวจสอบทุกธุรกรรมที่มีการเข้าถึง API ของระบบ DOPA-Digital ID รวมถึงการเก็บบันทึกข้อมูลจราจรคอมพิวเตอร์ (Log)
- สิทธิ์ในการระงับการให้บริการ: กรมการปกครองขอสงวนสิทธิ์ในการระงับสิทธิ์การเชื่อมโยงข้อมูล (Client ID / Client Secret) หรือหมายเลขไอพี (IP Address) ของหน่วยงานทันที หากตรวจพบพฤติกรรมการใช้งาน ที่เสี่ยงต่อความมั่นคงปลอดภัยของระบบ DOPA-Digital ID โดยจะแจ้งให้ทราบก่อนหรือหลังระงับก็ได้

2.2 แอปพลิเคชันไทยดี (ThaiID)

เป็นแอปพลิเคชันบนสมาร์ตโฟนสำหรับประชาชน (End-User) ทำหน้าที่เป็นเครื่องมือในการแสดง ตัวตน และเป็นช่องทางหลักในการให้ความยินยอม (Consent) เพื่อเปิดเผยข้อมูลส่วนบุคคลตามสิทธิและหลักการคุ้มครองข้อมูลส่วนบุคคล โดยมีข้อกำหนดการทำงาน ดังนี้

- การตรวจสอบสถานะ: ทุกครั้งที่มีการเปิดใช้งานแอปพลิเคชัน ThaiID ระบบจะตรวจสอบสถานะ บุคคลและสถานะบัตรประจำตัวประชาชนของผู้ใช้งานแบบเรียลไทม์ หากสถานะ บุคคลจำนายหรือระงับความ เคลื่อนไหวทางทะเบียน และสถานะบัตรประจำตัวประชาชนสิ้นสภาพการใช้งาน สถานะไม่ปกติ หรือหมดอายุเกิน 60 วัน ระบบจะดำเนินการระงับการใช้งานแอปพลิเคชันทันที
- การปรับปรุงข้อมูล: ทุกครั้งที่มีการเข้าใช้งานแอปพลิเคชัน ThaiID ระบบจะดำเนินการปรับปรุง ข้อมูลบัตรประจำตัวประชาชนของผู้ใช้งานให้เป็นปัจจุบันเสมอ

2.3 ผู้ให้บริการพิสูจน์และยืนยันตัวตนทางดิจิทัล (Relying Party: RP)

คือ ระบบงาน แอปพลิเคชัน หรือเว็บไซต์ของหน่วยงานภาครัฐและเอกชนที่ได้รับอนุญาตให้เชื่อมโยงกับระบบ DOPA-Digital ID โดยหน่วยงานผู้ให้บริการ (RP) จะต้องพัฒนาระบบให้สามารถรับ-ส่งข้อมูลกับผู้ให้บริการพิสูจน์และยืนยันตัวตน (IdP) ได้ตามมาตรฐานทางเทคนิคที่กรมการปกครองกำหนด พร้อมทั้งมีมาตรการคุ้มครองข้อมูลส่วนบุคคลและการรักษาความมั่นคงปลอดภัยอย่างเคร่งครัด โดยมีข้อกำหนด ดังนี้

1) **วัตถุประสงค์การใช้งาน:** อนุญาตให้ผู้ให้บริการพิสูจน์และยืนยันตัวตนได้เฉพาะในกระบวนการลงทะเบียนเพื่อสร้างบัญชีผู้ใช้งานใหม่ (Registration) การกู้คืนบัญชีผู้ใช้งาน (Account Recovery) และการปรับปรุงข้อมูลส่วนบุคคลให้เป็นปัจจุบัน (Data Updating) เท่านั้น โดยการนำข้อมูลไปใช้จะต้องสอดคล้องและเป็นไปตามหลักเกณฑ์ที่กฎหมาย หรือหน่วยงานกำกับดูแลที่เกี่ยวข้องกำหนดไว้อย่างเคร่งครัด

2) **ข้อจำกัดการใช้งาน:** ไม่อนุญาตให้นำบริการนี้ไปใช้ในขั้นตอนการยืนยันตัวตนเพื่อเข้าสู่ระบบ (Login / Authentication) ในการใช้งานครั้งถัดไป รวมถึงห้ามนำไปใช้เป็นเครื่องมือในการพิสูจน์และยืนยันตัวตนแบบพบหน้า ณ เคาน์เตอร์บริการ (Face-to-Face / Counter Service) ยกเว้นหน่วยงานที่ได้รับการอนุญาตจากกรมการปกครอง

3) **ความโปร่งใสในการใช้ข้อมูล:** RP ต้องแจ้งวัตถุประสงค์และรายละเอียดการนำข้อมูลส่วนบุคคลไปใช้งานให้ผู้ใช้งานทราบอย่างชัดเจน

4) **ความมั่นคงปลอดภัยของข้อมูล:** RP ต้องมีมาตรการและระบบการจัดเก็บข้อมูลส่วนบุคคลที่ได้รับไปอย่างมั่นคงปลอดภัยตามมาตรฐานที่กฎหมายกำหนด

3. ขั้นตอนการขอใช้บริการ

สำหรับหน่วยงานผู้ให้บริการ (Relying Party: RP) ที่ได้รับสิทธิ์และบัญชีผู้ใช้งาน (Account) จากกรมการปกครองเรียบร้อยแล้ว สามารถดำเนินการสร้างและบริหารจัดการสิทธิ์การเชื่อมโยง API ได้ตามขั้นตอนดังต่อไปนี้

3.1 การเข้าสู่ระบบบริหารจัดการหน่วยงาน

ผู้ดูแลระบบ (Administrator) ของหน่วยงาน RP ซึ่งประกอบด้วย ผู้ดูแลระบบระดับสูง (Senior Administrator) จำนวน 1 คน และผู้ดูแลระบบทั่วไป (Administrator) จำนวนไม่เกิน 9 คน สามารถดำเนินการเข้าสู่ระบบผ่านเว็บไซต์บริหารจัดการที่กรมการปกครองกำหนด ด้วยบัญชีผู้ใช้งานที่ได้รับอนุมัติ เพื่อเข้าสู่หน้าจอการจัดการแอปพลิเคชันของหน่วยงานตนเอง

3.2 การสร้างแอปพลิเคชันหรือสิทธิ์การเชื่อมโยงระบบฯ

ผู้ดูแลระบบ (Administrator) ทุกระดับ มีสิทธิ์ในการสร้างแอปพลิเคชันและชุดรหัสสิทธิ์การเชื่อมโยงระบบฯ (API Key) เพื่อนำไปใช้งานได้

3.3 การแก้ไขหรือยกเลิกแอปพลิเคชันหรือสิทธิ์การเชื่อมโยงระบบฯ

ผู้ดูแลระบบทั่วไป (Administrator) สามารถแก้ไขหรือยกเลิกสิทธิ์การเชื่อมโยงระบบฯ เฉพาะรายการที่ตนเองเป็นผู้สร้าง (เจ้าของสิทธิ์) เท่านั้น โดยทุกการดำเนินการแก้ไขหรือยกเลิก จะต้องได้รับการอนุมัติจากผู้ดูแลระบบระดับสูง (Senior Administrator) ผ่านการยืนยันตัวตนบนแอปพลิเคชันไทยดี (ThalID) จึงจะมีผลสมบูรณ์

3.4 การเก็บรักษาสิทธิ์การเชื่อมโยงระบบฯ (API KEY)

หน่วยงานผู้ให้บริการ (RP) มีหน้าที่รับผิดชอบโดยตรงในการเก็บรักษาสิทธิ์การเชื่อมโยงระบบฯ (API Key) ไว้เป็นความลับสูงสุด และต้องกำหนดมาตรการในการนำไปใช้งานให้มีความมั่นคงปลอดภัย เพื่อป้องกันการเข้าถึงหรือนำไปใช้โดยมิชอบ

4. เนื้อหาและขอบเขตการให้บริการ

ระบบพิสูจน์และยืนยันตัวตนทางดิจิทัล (DOPA-Digital ID) เปิดให้บริการแก่หน่วยงานผู้ให้บริการ (RP) และหน่วยงานผู้ให้บริการพิสูจน์และยืนยันตัวตน (Identity Provider: IdP) ภายใต้ขอบเขตการทำงานและชุดข้อมูลดังต่อไปนี้

4.1 รูปแบบการให้บริการหลัก ให้บริการข้อมูลเพื่อสนับสนุนการพิสูจน์และยืนยันตัวตนสำหรับการลงทะเบียนหรือสร้างบัญชีผู้ใช้งานใหม่ของระบบงานฝั่ง RP โดยอาศัยกระบวนการยืนยันตัวบุคคลและการให้ความยินยอม (Consent) จากเจ้าของข้อมูลผ่านแอปพลิเคชันไทยดี (ThalID) เพื่อให้ RP นำข้อมูลที่ได้รับมานำเชื่อถือไปประกอบการให้บริการประชาชนต่อไป

4.2 ขอบเขตชุดข้อมูลที่ให้บริการ (Data Scopes) ระบบจะจัดส่งข้อมูลส่วนบุคคลให้แก่ RP ผ่าน API ตามระดับสิทธิ์ที่หน่วยงานนั้นๆ ได้รับการอนุมัติ และต้องตรงตามความยินยอมที่ประชาชนได้อนุญาตบนแอปพลิเคชันไทยดี (ThalID) เท่านั้น

4.3 สภาพแวดล้อมการให้บริการ (Environments) กรมการปกครองได้จัดเตรียมระบบสำหรับการเชื่อมต่อไว้ 2 สภาพแวดล้อม เพื่อให้ RP สามารถพัฒนาระบบได้อย่างมีประสิทธิภาพ ดังนี้

1) ระบบทดสอบ (Sandbox Environment) สำหรับให้ RP ใช้ทดสอบการเชื่อมต่อ API การจำลองการให้ความยินยอมโดยการกรอกเลขประจำตัวประชาชนตามที่ RP กำหนด และตรวจสอบความถูกต้องของการรับ-ส่งข้อมูลทดสอบ

2) ระบบใช้งานจริง (Production Environment) สำหรับการให้บริการจริงแก่ประชาชน โดย RP ต้องเชื่อมต่อผ่านระบบเครือข่ายที่มีความมั่นคงปลอดภัยและปฏิบัติตามข้อกำหนดอย่างเคร่งครัด

4.4 ข้อจำกัดและเวลาการให้บริการ

1) ระบบของกรมการปกครองให้บริการตลอด 24 ชั่วโมง ทุกวัน

2) กรณีที่กรรมการปกครองมีความจำเป็นต้องปิดปรับปรุงระบบ (Maintenance) หรือเกิดเหตุขัดข้องทางเทคนิค กรรมการปกครองจะดำเนินการแจ้งให้หน่วยงาน RP ทราบล่วงหน้าผ่านช่องทางที่กำหนด

5. สถาปัตยกรรมระบบ

5.1 สถาปัตยกรรมการให้บริการยืนยันตัวตนผ่าน API ของ DIMS ประกอบด้วย

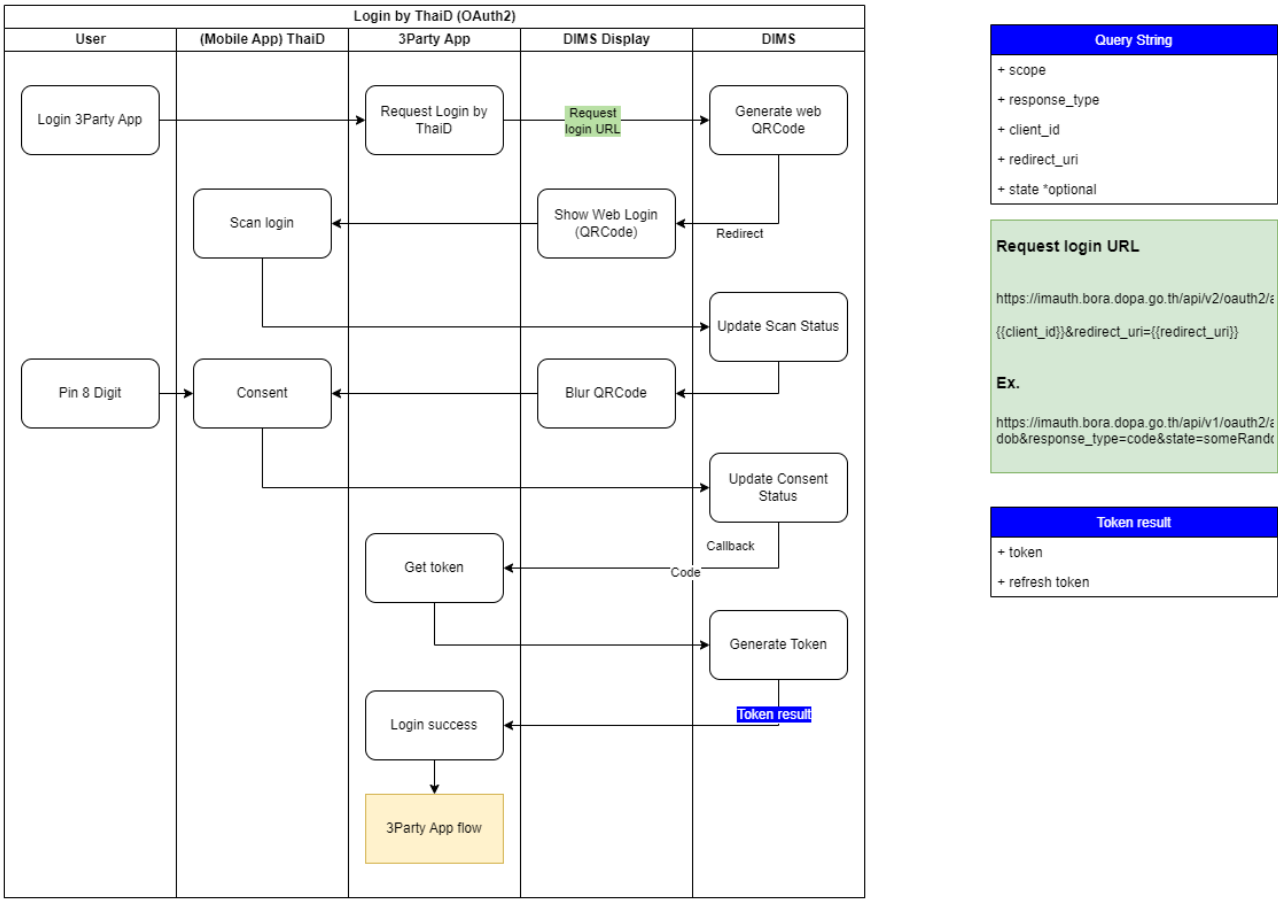
5.1.1 **User** หมายถึง ผู้ใช้งานแอปพลิเคชันไทยดี (ThaID)

5.1.2 **Mobile App ThaID** หมายถึง แอปพลิเคชันไทยดี (ThaID) บนสมาร์ตโฟน ทำหน้าที่เป็นเครื่องมือ (Authenticator) ให้ประชาชนยืนยันตัวตนทางดิจิทัลหรือยืนยันให้ความยินยอมทางอิเล็กทรอนิกส์

5.1.3 **3Party App** หมายถึง ระบบงาน แอปพลิเคชัน หรือเว็บไซต์ของหน่วยงานภาครัฐและเอกชน (Relying Party: RP) ที่ได้รับอนุมัติให้เชื่อมโยงระบบกับกรรมการปกครอง โดยดำเนินการเชื่อมต่อผ่านช่องทาง API เพื่อร้องขอรับบริการพิสูจน์และยืนยันตัวตนทางดิจิทัลของผู้ใช้งาน

5.1.4 **DIMS Display** หมายถึง ส่วนหน้าจอแสดงผลคิวอาร์โค้ด (QR Code) เพื่อให้ผู้ใช้งาน (User) นำแอปพลิเคชัน ThaID (ไทยดี) มาทำการสแกนเพื่อดำเนินการพิสูจน์และยืนยันตัวตนเข้าสู่ระบบ

5.1.5 **DIMS** หมายถึง ระบบบริหารจัดการการพิสูจน์และยืนยันตัวตนทางดิจิทัลของกรรมการปกครอง (DOPA Identity Management System) ทำหน้าที่เป็นระบบศูนย์กลาง (Identity Provider: IdP) ในการให้บริการเชื่อมต่อผ่านระบบ API เพื่อสนับสนุนกระบวนการพิสูจน์และยืนยันตัวบุคคลให้แก่หน่วยงานผู้ให้บริการ (Relying Party: RP)



Query String

Request login URL

Token result

Query String

Request login URL

Token result

6. พารามิเตอร์ในกระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตน

กระบวนการแลกเปลี่ยนข้อมูลการยืนยันตัวตนกับระบบของกรมการปกครอง มีการส่งผ่านข้อมูลที่ต้องการ พารามิเตอร์ ดังต่อไปนี้

6.1 Authentication

6.1.1 Authentication Request

Web Application/Mobile Application ของ RP จะส่ง authentication request ด้วย HTTPS GET request ไปยัง <https://imauth.bora.dopa.go.th/api/v2/oauth2/auth/>

ค่าพารามิเตอร์ของ Authentication Request

พารามิเตอร์	รายละเอียด
response_type	ระบุค่าเป็น “code” เนื่องจากเป็นการร้องขอสิทธิการเข้าถึงข้อมูล แบบ authorization code
client_id	ระบุค่า client identifier ที่กรมการปกครองออกให้กับ RP ที่ผ่านการลงทะเบียนแล้ว
redirect_uri	ระบุค่า URI ที่ RP ลงทะเบียนไว้กับกรมการปกครอง เพื่อใช้ในการรับ authorization code
scope	ขอบเขตหรือชุดของข้อมูลที่ RP ร้องขอสิทธิการเข้าถึง โดยเลือกระบุค่าจากข้อมูลที่กรมการปกครองเปิดให้ร้องขอ ดังนี้ (1) pid คือ หมายเลขประจำตัวประชาชน 13 หลัก (2) name คือ ชื่อ-นามสกุล ภาษาไทย (3) name_en คือ ชื่อ-นามสกุล ภาษาอังกฤษ (4) birthdate คือ วัน เดือน ปีค.ศ.เกิด (เช่น 1989-12-28) (5) address คือ ที่อยู่ตามหน้าบัตรประจำตัวประชาชน (6) given_name คือ ชื่อ ภาษาไทย (7) middle_name คือ ชื่อกลาง ภาษาไทย (8) family_name คือ นามสกุล ภาษาไทย (9) given_name_en คือ ชื่อ ภาษาอังกฤษ (10) middle_name_en คือ ชื่อกลาง ภาษาอังกฤษ (11) family_name_en คือ นามสกุล ภาษาอังกฤษ (12) gender คือ เพศ (เช่น male) (13) smartcard_code คือ เลขใต้รูป

พารามิเตอร์	รายละเอียด
	(14) title คือ คำนำหน้านามภาษาไทย (15) title_en คือ คำนำหน้านามภาษาอังกฤษ (16) ial คือ ระดับความเข้มข้นในการพิสูจน์ตัวตน (17) date_of_issuance คือ วันที่ออกบัตร (18) date_of_expiry คือ วันที่บัตรหมดอายุ (19) house_address คือ ที่อยู่ตามทะเบียนบ้าน โดย formatted คือ ที่อยู่จัดรูปแบบแล้ว , raw คือที่อยู่คั่นด้วย # (เลขที่#หมู่ที่#ตรอก#ซอย#ถนน#ตำบล#อำเภอ#จังหวัด), id คือ เลขรหัสประจำบ้าน 11 หลัก (20) openid คือ id_token ที่มีข้อมูลผู้ใช้บริการที่ RP ร้องขอ หากมีข้อมูลหลายอัน ให้แยกข้อมูลแต่ละอันด้วยการเว้นวรรค 1 วรรค (หรือ %20 ในระบบ Base64 url encoded)
verify_type	ขอบเขตการกำหนดรูปแบบการยืนยันตัวบุคคลที่ต้องการใช้งานตามสิทธิการยืนยันตัวบุคคลตามที่กรรมการปกครองกำหนดให้ ให้กับ scope ที่ร้องขอเดิมประกอบด้วย ● pin คือการกำหนดรูปแบบการยืนยันตัวบุคคลด้วย PIN (ค่าเริ่มต้น) ● face คือการกำหนดรูปแบบการยืนยันตัวบุคคลด้วยภาพใบหน้า ● pin_face คือกำหนดรูปแบบการยืนยันตัวบุคคลด้วย PIN และ ภาพใบหน้า การเลือกรูปแบบการยืนยันตัวบุคคลสามารถเลือกได้เพียง 1 รูปแบบเท่านั้น หากไม่กำหนดจะเป็นการเลือกใช้รูปแบบการยืนยันตัวบุคคลด้วย PIN โดยอัตโนมัติ การใช้สิทธิการยืนยันตัวบุคคลด้วยภาพใบหน้าหรือ PIN และภาพใบหน้า จะต้องมีสิทธิในการใช้งานการยืนยันตัวบุคคลด้วยภาพใบหน้าจากกรรมการปกครองก่อน
state	random string ใช้ในการตรวจสอบความสัมพันธ์ระหว่าง request จาก RP กับ response จาก server ของกรรมการปกครอง

ตัวอย่างการใช้งานเป็นดังนี้

Method	GET
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/auth/?response_type=code &client_id={{clientIdFromDOPA}}&redirect_uri=https://rp.example.org/api/callback &scope=pid%20name%20birthdate%20openid&verify_type=pin_face&state=af0ifjsldkj
Header	“Content-type”: “application/x-www-form-urlencoded”

6.1.2 Authentication Response

Authorization code เป็น credential ที่ออกโดย server ของกรมการปกครองให้กับ Web Application/Mobile Application ของ RP เพื่อใช้เป็นหลักฐานว่าผู้ใช้บริการได้ผ่านการยืนยันตัวตนและให้ความยินยอมในการเปิดเผยข้อมูลแล้ว server ของกรมการปกครองจะส่ง authorization code ให้กับ Web Application/Mobile Application ของ RP ด้วยการส่ง HTTPS response กลับไปยัง redirect URI ตามที่ลงทะเบียน

ค่าพารามิเตอร์ของ Authentication Response

พารามิเตอร์	รายละเอียด
code	authorization code เพื่อใช้ในการร้องขอ access token
state	state เป็นค่าเดียวกันกับ state ใน authentication request

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	302 Found
Payload	https://rp.example.org/api/callback?code=nnqtYcoik7cjtHQYyn3Af8uk4LG3rYYh &state=af0ifjsldkj

6.1.3 Authentication Error Response

หากมีข้อผิดพลาดในกระบวนการยืนยันตัวตนนอกเหนือจากปัญหาจาก redirect URI เช่น ผู้ใช้งานไม่ผ่านการยืนยันตัวตน หรือไม่ยินยอมที่จะเปิดเผยข้อมูล server ของกรมการปกครองจะแจ้ง error code ให้กับ Web Application /Mobile Application ของ RP ด้วยการส่ง HTTPS response กลับไปยัง redirect URI ตามที่ลงทะเบียนไว้

ค่าพารามิเตอร์ของ Authentication Error Response

พารามิเตอร์	รายละเอียด
error	error code แจ้งสาเหตุของข้อผิดพลาดที่เกิดขึ้น
error_description	คำอธิบาย error code ในรูปแบบ text
error_uri	URI ที่ระบุข้อมูลเพิ่มเติมของ error อาจเป็น Webpage
state	state เป็นค่าเดียวกันกับ state ใน authentication request

ตัวอย่าง error code ของ authentication error response อ้างอิงหัวข้อที่ 7

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	302 Found
Payload	https://rp.example.org/api/callback?error=invalid_request &error_description=Unsupported%20response_type&state=af0ifjsldkj

6.2 การขอ Token

6.2.1 Token Request

Web Application/Mobile Application ของ RP ใช้ authorization code เพื่อร้องขอข้อมูลในการยืนยันตัวตน ผู้ใช้บริการจากกรมการปกครอง ด้วยการส่ง HTTPS POST request

ค่าพารามิเตอร์ของ Access Token Request

พารามิเตอร์	รายละเอียด
authorization	ใช้ค่า “Basic” + Base64({{client_id}}:{{client_secret}})
grant_type	ใช้ค่า “authorization_code”
code	authorization code ที่ได้รับมาก่อนหน้า
redirect_uri	URI เป็นค่าเดียวกันกับ redirect_uri ใน authentication request

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/token/
Header	{ “Content-type”: “application/x-www-form-urlencoded”, “Authorization”: “Basic authorization” }
Body	grant_type=authorization_code code=code redirect_uri=redirect_uri

6.2.2 Token Response

Server ของกรมการปกครองตรวจสอบ authorization code ที่ได้รับ หากถูกต้อง ก็จะส่ง token response พร้อมกับข้อมูลยืนยันตัวตนกลับมายัง web/mobile application ของ RP ด้วยการส่ง HTTPS POST response กลับไปยัง redirect URI ตามที่ระบุใน token request โดย token response

ค่าพารามิเตอร์ของ Token Response

พารามิเตอร์	รายละเอียด
access_token	String มีอายุ 15 นาที
token_type	ใช้ค่า “Bearer”
expire_in	วัน เวลาที่ access token หมดอายุ รูปแบบ Unix timestamp (second)
scope	scope ของข้อมูลที่ได้รับ
*id_token	Option ถ้า scope=openid คือ id_token ที่มีข้อมูลผู้ใช้บริการที่ RP ร้องขอ
**scope value	String ที่เก็บ value ของ scope นั้น ๆ

* id_token จะเก็บข้อมูลตามมาตรฐาน OpenID Connect โดยสามารถตรวจสอบกระบวนการ verify ได้ที่ <https://imauth.bora.dopa.go.th/.well-known/openid-configuration> จะ return เฉพาะกรณีกำหนด scope openid เท่านั้น

** scope value เช่น “pid”: “หมายเลขประจำตัวประชาชน 13 หลัก” “name”: “ชื่อ-นามสกุล ภาษาไทย” เป็นต้น จะ return ให้เฉพาะกรณีไม่กำหนด scope openid

ตัวอย่างการใช้งานเป็นดังนี้

กรณีไม่กำหนด scope openid

Response Status	200 OK
Payload	{ "expire_in": 1612857374, "access_token": "access_token", "refresh_token": "refresh_token", "token_type": "Bearer", "scope": "pid name", "pid": " pid ", "name": " name " }

กรณีกำหนด scope openid

Response Status	200 OK
Payload	{ "expire_in": 1612857374, "access_token": "access_token", "refresh_token": "refresh_token", "token_type": "Bearer", "scope": "pid name openid", "id_token": "id_token jwt", }

ตัวอย่าง error code response อ้างอิงหัวข้อที่ 7

6.2.3 ID Token

id_token จะมีข้อมูลผู้ให้บริการที่ RP ร้องขอ มีอายุใช้งานตามที่กำหนด มีการลง signature จากกรรมการปกครอง และมีการเข้ารหัสด้วย Base64 ภายใน id_token จะมีค่าพารามิเตอร์ดังนี้

พารามิเตอร์	รายละเอียด
at_hash	Access Token hash value
aud	App ที่สามารถใช้งานได้
exp	วัน เวลา หมดอายุ
iat	วัน เวลา ที่ออก token
iss	ผู้ที่ออก token
sub	Subject Identifier
*scope value	String ที่เก็บ value ของ scope นั้น ๆ

* scope value เช่น “pid” : “หมายเลขประจำตัวประชาชน 13 หลัก” “name” : “ชื่อ-นามสกุล ภาษาไทย” เป็นต้น

ตัวอย่างข้อมูลผู้ให้บริการที่ RP ร้องขอ

pid	<i>pid</i>
name	<i>name</i>
birthdate	<i>birthdate</i>

6.3 การ Token Introspect

6.3.1 Token Introspect Request

ค่าพารามิเตอร์ Token Introspect Request

พารามิเตอร์	รายละเอียด
token	token มีอายุ 15 นาที

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/introspect/
Header	{ "Content-type": "application/x-www-form-urlencoded", "Authorization": "Basic authorization" }
Body	token=Bearer token

6.3.2 Token Introspect Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	200 OK
Payload	{ "active": true, "sub": "1639800072121", "scope": "pid name" }

Response Status	200 OK
Payload	{ "active": false }

6.3.3 Token Introspect Error Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	400 Bad Request
Payload	{ "error": "invalid_request", "error_description": "The body is invalid" }

6.4 การ Token Revocation

6.4.1 Token Revocation Request จะมีค่าพารามิเตอร์ ดังนี้

พารามิเตอร์	รายละเอียด
token	token ที่ต้องการยกเลิก

ตัวอย่างการใช้งานเป็นดังนี้

Method	POST
URL	https://imauth.bora.dopa.go.th/api/v2/oauth2/revoke/
Header	{ "Content-type": "application/x-www-form-urlencoded", "Authorization": "Basic authorization" }
Body	token = Bearer token

6.4.2 Token Revocation Response

ตัวอย่างการใช้งานเป็นดังนี้

Response Status	200 OK
Payload	{ “status”:”OK”, “message”:”revoked” }

CONFIDENTIAL

7. ข้อเสนอแนะ

- Status คือ HTTP Status Code ที่ระบบจะแจ้งกลับ (Response) มายังต้นทางทราบ ดังนี้

Code Response	Error	Error Description
400	invalid_request	The require parameter is missing or invalid
400	invalid_scope	The scope is invalid
400	invalid_request	The redirect or callback url mismatch or invalid
400	invalid_request	Invalid Authorization Code
400	unsupported_response_type	Unsupported response type
400	unsupported_grant_type	Unsupported grant type
400	unsupported_token_hint	Unsupported token hint
400	unsupported_token_type	Unsupported token type
400	duplicate_request	The duplicate request is not allowed
400	server_error	Something went wrong, please try again in the moment
401	unauthorized_client	The client is not authorized
401	invalid_client	Client id not found
401	user_denied	User denied the request (disapproved)
401	invalid_refresh_token	Verify refresh token failed
401	invalid_refresh_token	Invalid refresh token
401	invalid_refresh_token	Cannot refresh access token
401	access_denied	You're not allowed
401	access_denied	You're not allowed as Authorative Source
401	access_denied	You don't have permission to access this service
403	verify_permission_denied	You don't have permission to use face verify
404	not found data	

-
- Response จะอยู่ในรูปแบบ JSON แต่มีบางคำสั่งจะไม่มีข้อมูลตอบกลับ ขึ้นอยู่กับ Status
 - ทุก request parameters จะต้องมีการกำหนดค่า ยกเว้นที่ระบุไว้เป็น [optional]

CONFIDENTIAL